GUIA PRÁTICO · FORENSE DIGITAL

Hash e integridade de arquivos na prova digital

Funções hash, por que MD5 e SHA-1 ficaram para trás, como calcular SHA-256 em qualquer sistema e onde tudo isso encontra a cadeia de custódia do CPP.

```
$ printf 'laudo pericial' | sha256sum
ddaf6eb3051ea2fe…ed07386f  -
```

Fernando Menolli Neto

Dev Ruby on Rails, formado em Sistemas de Informação. Constrói SaaS e escreve sobre prova digital e ferramentas open source.
Agente de Polícia Judiciária. Perfil pessoal: não fala pela instituição.

Material educativo · Não constitui orientação jurídica · Edição de outubro de 2026

ANTES DE COMEÇAR

Aviso, público e como usar este guia

AVISO IMPORTANTE

Este guia tem finalidade **exclusivamente educativa**. Ele **não é orientação jurídica**, não substitui a leitura da legislação, da jurisprudência e das normas técnicas aplicáveis, e não substitui o trabalho de perito oficial, advogado ou outro profissional habilitado. Em um caso concreto, procure quem tem atribuição e responsabilidade para atuar nele.

O guia também não descreve procedimentos internos de nenhum órgão público, não trata de casos reais e não ensina formas de contornar exames periciais. Os exemplos são genéricos, e os valores de hash mostrados foram calculados a partir de textos de exemplo criados para este material.

Para quem é

Para quem está começando ou já tem alguma base técnica: desenvolvedores, estudantes que se preparam para concursos de perícia e profissionais de TI que querem entender, sem mistificação, como uma sequência de caracteres hexadecimais ajuda a demonstrar que um arquivo não foi alterado.

O que você vai encontrar

- Os conceitos: o que é uma função hash e quais propriedades importam para a prova digital.
- O estado atual dos algoritmos: por que MD5 e SHA-1 não devem mais ser usados, sozinhos, para garantir integridade, com as referências públicas.
- A diferença entre *integridade* e *autenticidade*, origem da maior parte dos mal-entendidos.
- Comandos prontos para macOS, Linux e Windows.
- Os erros mais comuns no dia a dia.
- O texto dos arts. 158-A a 158-F do Código de Processo Penal (cadeia de custódia), conferido na fonte oficial, e uma leitura técnica de onde o hash entra.
- Um checklist de uma página para imprimir.

Convenções

Comandos aparecem em blocos escuros; o que vem depois de `#` é comentário. Trechos de lei aparecem em caixas com fonte serifada e indicam a fonte. Pontos sobre os quais o autor não tem certeza, ou que dependem de interpretação jurídica, estão marcados com o selo PONTO INCERTO.

Sobre o autor

Fernando Menolli Neto. Dev Ruby on Rails, formado em Sistemas de Informação. Constrói SaaS e escreve sobre prova digital e ferramentas open source. Agente de Polícia Judiciária. Este é um perfil pessoal: o autor não fala pela instituição, e este material reflete estudo pessoal, sem representar posição institucional de nenhum órgão.

SUMÁRIO

Conteúdo

01 Por que hash importa na prova digital 4

02 O que é uma função hash 5
Definição, tamanho fixo e uma analogia útil (e seus limites)

03 As propriedades que importam 6
Determinismo, efeito avalanche, resistência a pré-imagem e a colisão

04 MD5 e SHA-1 x SHA-256 7
Linha do tempo das quebras, SHAttered (2017) e recomendações atuais

05 Integridade x autenticidade 9
O hash prova que o arquivo não mudou, não que é verdadeiro

06 Calculando o hash na prática 10
macOS, Linux e Windows: arquivo, conferência e pastas inteiras

07 Erros comuns 11

08 Cadeia de custódia no CPP (arts. 158-A a 158-F) 12
Texto legal conferido no Planalto e leitura técnica

09 Pontos jurídicos em aberto 15

10 Ferramenta, referências e leituras 16

✓ Checklist de uma página 17

CAPÍTULO 01

Por que hash importa na prova digital

Um arquivo digital pode ser copiado sem perda e alterado sem deixar marca visível. A prova digital precisa de um jeito objetivo de responder: “isto é exatamente o que foi coletado?”

Um documento em papel envelhece, amassa, recebe carimbos. Uma alteração costuma deixar algum rastro físico. Um arquivo digital é diferente: é uma sequência de bits, e trocar um único bit não deixa marca aparente. Uma fotografia pode ter um pixel modificado, uma planilha pode ter um valor trocado, um áudio pode ter um trecho cortado, e o arquivo resultante parece tão “original” quanto o anterior.

Ao mesmo tempo, copiar um arquivo produz uma réplica bit a bit idêntica. Isso é ótimo para a perícia, porque permite trabalhar sobre cópias e preservar o original, mas cria uma pergunta permanente: **como demonstrar que a cópia analisada é idêntica ao que foi coletado, e que nada mudou entre a coleta e o laudo?**

A resposta técnica padrão é a função hash criptográfica. Calcula-se um valor curto, uma espécie de “impressão digital” do conteúdo, no momento da coleta. Depois, a qualquer tempo, qualquer pessoa pode recalcular esse valor sobre o arquivo e comparar. Se for igual, há forte evidência técnica de que o conteúdo não mudou. Se for diferente, algo mudou, ainda que seja um único bit.

> **A IDEIA CENTRAL EM UMA FRASE**
>
> O hash não guarda o arquivo nem o “protege”: ele permite **verificar**, depois, se o conteúdo continua idêntico ao que existia quando o valor foi calculado e registrado.

O que o hash não faz

Vale adiantar os limites, porque eles aparecem ao longo de todo o guia:

- **Não impede alterações.** Só permite detectá-las.
- **Não prova autoria, origem ou veracidade.** Um arquivo forjado também tem hash, e esse hash continua o mesmo enquanto ninguém alterar o arquivo forjado (capítulo 05).
- **Não vale nada sozinho.** Um valor de hash só tem força se ficar registrado de forma confiável, com data, responsável, algoritmo e contexto. É aqui que entra a cadeia de custódia (capítulo 08).
- **Não cobre o que está fora do conteúdo.** Nome do arquivo, datas do sistema de arquivos e permissões geralmente não fazem parte do cálculo (capítulo 07).

Onde ele aparece no trabalho forense

De forma genérica, em documentação técnica pública e em normas como a ISO/IEC 27037 (diretrizes para identificação, coleta, aquisição e preservação de evidência digital), o hash costuma aparecer em pelo menos três momentos: na **aquisição** (calcular o valor do material original ou da cópia forense), na **verificação** (confirmar que a cópia é idêntica à origem) e na **análise e no laudo** (registrar os valores para que terceiros, inclusive uma eventual contraperícia, possam conferir).

CAPÍTULO 02

O que é uma função hash

Uma função que recebe dados de qualquer tamanho e devolve um valor de tamanho fixo, calculado de forma que pequenas mudanças na entrada gerem resultados completamente diferentes.

Formalmente, uma **função hash** é uma função `H` que mapeia uma entrada de tamanho arbitrário (um texto, um arquivo de 4 KB, uma imagem de disco de 2 TB) para uma saída de tamanho fixo, chamada *resumo*, *digest* ou simplesmente *hash*. No SHA-256, a saída tem sempre 256 bits, normalmente escritos como 64 caracteres hexadecimais.

Um exemplo real, calculado com `sha256sum` sobre o texto `laudo pericial` (sem quebra de linha no final):

```
$ printf 'laudo pericial' | sha256sum
ddaf6eb3051ea2fe2522b97254af0388261476776340bfcdb3a9c295ed07386f  -
```

E dois vetores de teste conhecidos do SHA-256, úteis para conferir se uma ferramenta está calculando corretamente:

Entrada	SHA-256
vazia (0 bytes)	`e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855`
`abc` (3 bytes)	`ba7816bf8f01cfea414140de5dae2223b00361a396177a9cb410ff61f20015ad`

Hash criptográfico x checksum comum

Existem funções que também geram valores de tamanho fixo, como o CRC32, mas que foram feitas para detectar **erros acidentais** (ruído em transmissão, setor defeituoso). Elas não foram projetadas para resistir a alguém que **quer** produzir dois conteúdos com o mesmo resultado. Na prova digital, a preocupação não é só com acidentes; por isso se usam **funções hash criptográficas**, como as da família SHA-2.

Uma analogia útil, com limites

É comum comparar o hash a uma impressão digital: algo pequeno que identifica algo grande. A analogia ajuda, mas tem dois limites importantes:

- **Não dá para "reconstruir" o arquivo a partir do hash**, assim como não se reconstrói uma pessoa a partir da digital. O hash não é compressão nem criptografia; não existe "descriptografar um hash".
- **Colisões existem matematicamente.** Como há infinitas entradas possíveis e uma quantidade finita de saídas (2^{256} no SHA-256), necessariamente existem entradas diferentes com o mesmo hash. O que uma boa função garante é que **encontrar** esses pares seja computacionalmente inviável na prática (capítulo 03).

Hash não é criptografia

Criptografia é reversível para quem tem a chave: cifra-se para depois decifrar. Hash é uma via de mão única e não usa chave. Essa confusão aparece com frequência em questões de concurso e em conversas do dia a dia, e vale fixar: **calcular o hash de um arquivo não o torna sigiloso nem protegido**; o arquivo continua exatamente como estava.

> **PARA FIXAR**
>
> - Entrada de qualquer tamanho → saída de tamanho fixo.
> - Mesma entrada → sempre a mesma saída.
> - Hash não é reversível, não usa chave e não é criptografia.
> - Na prova digital, usam-se funções hash *criptográficas*, não checksums simples.

CAPÍTULO 03

As propriedades que importam

Determinismo, efeito avalanche e resistência a colisão explicam por que o hash funciona como ferramenta de integridade. Resistência a pré-imagem e a segunda pré-imagem completam o quadro.

1. Determinismo

A mesma entrada produz sempre a mesma saída, em qualquer computador, sistema operacional ou ferramenta que implemente corretamente o algoritmo. É isso que permite que um valor calculado no momento da coleta seja recalculado anos depois, por outra pessoa, com outra ferramenta, e comparado. Se o `sha256sum` do Linux e o `Get-FileHash` do Windows derem resultados diferentes para o "mesmo" arquivo, o problema está no que está sendo de fato lido, não no algoritmo.

2. Efeito avalanche

Uma alteração mínima na entrada muda a saída de forma drástica e imprevisível: em média, cerca de metade dos bits da saída muda. Veja dois textos que diferem em uma única letra (`l` minúsculo x `L` maiúsculo):

Entrada	SHA-256
`laudo pericial`	`ddaf6eb3051ea2fe2522b97254af0388261476776340bfcdb3a9c295ed07386f`
`Laudo pericial`	`e889cfd08337a9d494e858b110fac4515aca934fcaf70ddb410527b5579fe08c`

Nesse exemplo, calculado para este guia, **126 dos 256 bits** da saída são diferentes, muito perto da metade. Não há "semelhança" entre os resultados que permita inferir que as entradas eram parecidas. Na prática, **não existe alteração pequena demais para ser detectada**: um bit trocado em uma imagem de disco de vários terabytes muda completamente o hash.

3, 4 e 5. Pré-imagem, segunda pré-imagem e colisão

Resistência a pré-imagem (unidirecionalidade): dado um hash, deve ser inviável encontrar *qualquer* entrada que o produza. É por isso que se diz que o hash é "de mão única".

Resistência a segunda pré-imagem: dado um arquivo específico, deve ser inviável encontrar *outro* arquivo com o mesmo hash. É a propriedade mais diretamente ligada ao cenário "trocar a evidência já registrada por outra com o mesmo hash".

Resistência a colisão: deve ser inviável encontrar *quaisquer dois* arquivos diferentes com o mesmo hash, mesmo que se possa escolher livremente os dois. É uma exigência mais forte que a anterior, e é justamente a que caiu no MD5 e no SHA-1.

> **POR QUE COLISÃO IMPORTA SE NINGUÉM "ESCOLHEU" A EVIDÊNCIA?**
>
> Quando colisões são práticas, é possível preparar **antecipadamente** dois arquivos com o mesmo hash e conteúdos diferentes. Além disso, a simples existência do ataque permite questionar a confiabilidade do registro. Em um contexto em que a integridade será discutida por partes com interesses opostos, usar um algoritmo com colisões públicas enfraquece a demonstração, mesmo que nenhum ataque tenha ocorrido no caso concreto.

Quanto é "inviável"?

Para uma função ideal de n bits, achar uma colisão por força bruta exige da ordem de $2^{n/2}$ tentativas ("paradoxo do aniversário"); achar uma pré-imagem, da ordem de 2^{n}. No SHA-256, são cerca de 2^{128} operações para colisão. MD5 (128 bits, 2^{64} no ideal) e SHA-1 (160 bits, 2^{80} no ideal) sofreram ataques específicos que reduziram muito esses números (capítulo 04).

CAPÍTULO 04

MD5 e SHA-1 x SHA-256

MD5 e SHA-1 foram padrão por muitos anos e ainda aparecem em ferramentas e laudos antigos. Hoje existem colisões públicas e práticas para ambos. Para demonstrar integridade, o padrão atual é SHA-256 (família SHA-2) ou superior.

Algoritmo	Saída	Hex	Situação quanto à resistência a colisão
MD5	128 bits	32 caracteres	Quebrada. Colisões publicadas em 2004; segundo a RFC 6151, encontradas em cerca de um minuto (ou menos) em computador comum já em 2006–2007.
SHA-1	160 bits	40 caracteres	Quebrada. Primeira colisão real em 2017 (SHAttered); colisão de prefixo escolhido em 2020 ("SHA-1 is a Shambles"). Aposentada pelo NIST.
SHA-256	256 bits	64 caracteres	Sem colisão conhecida. Padronizada no FIPS 180-4 (NIST). Recomendada.
SHA-512 / SHA3-256	512 / 256 bits	128 / 64	Sem colisão conhecida. Alternativas válidas (FIPS 180-4 e FIPS 202).

Linha do tempo (fatos públicos)

Ano	Evento
1992	MD5 publicado como RFC 1321 (R. Rivest).
1995	SHA-1 padronizado no FIPS 180-1.
2004–2005	Wang, Feng, Lai e Yu publicam colisões para MD5 (IACR ePrint 2004/199). As técnicas detalhadas saem no EUROCRYPT 2005 (Wang e Yu, "How to Break MD5 and Other Hash Functions").
2007–2009	Stevens, Lenstra e de Weger demonstram colisões de *prefixo escolhido* para MD5, aplicadas a certificados X.509 (EUROCRYPT 2007). No CRYPTO 2009, trabalho de Stevens e coautores descreve a criação de um certificado falso de autoridade certificadora com colisões MD5.
2011	RFC 6151 (IETF) registra que o MD5 "não é mais aceitável onde resistência a colisão é exigida", como em assinaturas digitais.
23/02/2017	**SHAttered**: CWI Amsterdam e Google anunciam a primeira colisão do SHA-1 completo, com dois PDFs diferentes de mesmo SHA-1 (Stevens, Bursztein, Karpman, Albertini e Markov, "The first collision for full SHA-1", CRYPTO 2017; IACR ePrint 2017/190).
2020	Leurent e Peyrin, "SHA-1 is a Shambles" (IACR ePrint 2020/014; USENIX Security 2020): primeira colisão de prefixo escolhido do SHA-1 na prática, aplicada a chaves PGP/GnuPG.
15/12/2022	NIST anuncia a aposentadoria do SHA-1, recomenda migrar para SHA-2 ou SHA-3 e fixa 31/12/2030 como prazo para a retirada.

O que foi o SHAttered, em números

Segundo o anúncio no blog de segurança do Google (fev. 2017), o cálculo exigiu cerca de **nove quintilhões** (9.223.372.036.854.775.808) de computações de SHA-1: **6.500 anos de CPU** na primeira fase e **110 anos de GPU** na segunda. Foi caro, mas viável para uma organização com recursos. Três anos depois, Leurent e Peyrin estimaram, no resumo de "SHA-1 is a Shambles", um custo de cerca de **US$ 11 mil** para uma colisão e **US$ 45 mil** para uma colisão de prefixo escolhido, com GPUs alugadas. Os autores concluem que os ataques práticos contra o MD5 desde 2009 passaram a ser práticos também contra o SHA-1.

NUANCE QUE COSTUMA CAIR EM PROVA

Os ataques práticos conhecidos contra MD5 e SHA-1 são de **colisão**. A RFC 6151 registra que o melhor ataque de pré-imagem contra o MD5 conhecido à época tinha complexidade de $2^{123,4}$, ainda muito alta. Ou seja: hashes MD5/SHA-1 antigos não "viraram lixo"; um valor registrado no passado continua útil para detectar alteração *acidental* ou conferir uma cópia. O problema é que eles **não sustentam mais, sozinhos, uma demonstração robusta de integridade** diante de um adversário, porque colisões são práticas. Para material novo, use SHA-256.

E calcular mais de um algoritmo?

Muitas ferramentas forenses calculam MD5 e SHA-1 junto com SHA-256, por compatibilidade com registros e bases de dados antigas. Não há problema em registrar vários valores, desde que pelo menos um deles seja de um algoritmo sem colisões conhecidas, como o SHA-256, e que fique claro qual algoritmo gerou cada valor.

CAPÍTULO 05

Integridade x autenticidade

O hash prova que o arquivo não mudou desde que o valor foi calculado e registrado. Ele não prova que o arquivo é verdadeiro, quem o criou, quando foi criado nem que o conteúdo corresponde aos fatos.

INTEGRIDADE

O conteúdo atual é **idêntico, bit a bit**, ao do momento em que o hash foi calculado.

O hash responde a isso, desde que o valor de referência tenha sido registrado de forma confiável.

AUTENTICIDADE

O arquivo é **o que diz ser**: veio de quem se afirma, no contexto que se afirma, e não é uma fabricação ou montagem.

O hash, sozinho, não responde a isso.

Um exemplo genérico

Imagine um print de tela editado em um programa de imagem antes de ser entregue. No momento da entrega, calcula-se o SHA-256 e registra-se o valor. A partir daí, toda conferência vai bater: o hash demonstra, corretamente, que **aquele** arquivo, já editado, não mudou desde a entrega. Ele não diz nada sobre o que aconteceu **antes** do cálculo.

Em outras palavras: **o hash "congela" um estado; ele não certifica esse estado.** A pergunta "este conteúdo é genuíno?" exige outros elementos.

O que ajuda a sustentar a autenticidade

- **Momento e forma da coleta.** Um hash calculado na fonte, na aquisição, vale muito mais que um calculado depois de várias transferências.
- **Registro do contexto.** De onde veio, quem coletou, com qual ferramenta e versão, data e hora, estado do dispositivo.
- **Assinatura digital.** Assinar o arquivo, ou o registro que contém os hashes, com um certificado vincula o conteúdo a um signatário. No Brasil, a MP nº 2.200-2/2001 instituiu a ICP-Brasil.
- **Carimbo do tempo.** Serviços de carimbo do tempo associam um hash a uma data e hora atestadas por terceiro.
- **Análise pericial do conteúdo e dos metadados.** Coerência interna do arquivo, metadados, vestígios de edição, comparação com outras fontes. É trabalho de perícia, não de uma função hash.
- **Cadeia de custódia documentada.** A história cronológica de posse e manuseio (capítulo 08).

ONDE O HASH PRECISA MORAR

Se o valor de referência fica guardado **ao lado do arquivo**, quem consegue alterar o arquivo também consegue alterar o hash. O valor de referência precisa estar em um registro independente e confiável: documento assinado, termo, laudo, sistema com trilha de auditoria. O hash transfere a confiança do arquivo para o registro do hash; ele não cria confiança do nada.

Hash e sigilo

Divulgar o hash de um arquivo não revela o conteúdo. Mas, se o conteúdo for curto e previsível (um número de documento, uma senha fraca, uma palavra), é possível calcular hashes de todas as possibilidades e comparar. Por isso o hash, sozinho, não deve ser tratado como forma de anonimizar dados pessoais.

CAPÍTULO 06

Calculando o hash na prática

macOS, Linux e Windows já trazem ferramentas nativas para SHA-256. Não é preciso instalar nada.

macOS: `shasum`

```
# calcular o SHA-256 de um arquivo
$ shasum -a 256 evidencia.bin
# salvar o resultado em um arquivo de referência
$ shasum -a 256 evidencia.bin > evidencia.sha256
# conferir depois (imprime "evidencia.bin: OK" se bater)
$ shasum -a 256 -c evidencia.sha256
```

Sem `-a 256`, o `shasum` usa SHA-1 por padrão. Esse é um erro frequente.

Linux: `sha256sum` (GNU coreutils)

```
# calcular
$ sha256sum evidencia.bin
# salvar e conferir
$ sha256sum evidencia.bin > evidencia.sha256
$ sha256sum -c evidencia.sha256
evidencia.bin: OK
```

Windows: `Get-FileHash` (PowerShell)

```
# SHA256 é o padrão do Get-FileHash; deixar explícito evita dúvida
PS> Get-FileHash .\evidencia.bin -Algorithm SHA256
# comparar com o valor de referência completo (-eq não diferencia maiúsculas)
PS> (Get-FileHash .\evidencia.bin -Algorithm SHA256).Hash -eq "<valor de referência>"
# alternativa no Prompt de Comando (cmd)
> certutil -hashfile evidencia.bin SHA256
```

O PowerShell exibe o hash em hexadecimal maiúsculo; Linux e macOS, em minúsculo. É o mesmo valor.

Pastas inteiras

```
# Linux: um hash por arquivo, em ordem estável, salvo em manifesto
$ find pasta/ -type f -print0 | sort -z | xargs -0 sha256sum > manifesto.sha256
$ sha256sum -c manifesto.sha256
# macOS
$ find pasta/ -type f -print0 | xargs -0 shasum -a 256 > manifesto.sha256
$ shasum -a 256 -c manifesto.sha256
# Windows (PowerShell): exporta caminho, algoritmo e hash para CSV
PS> Get-ChildItem .\pasta -Recurse -File | Get-FileHash -Algorithm SHA256 |
      Export-Csv manifesto.csv -NoTypeInformation
```

Salve o manifesto **fora** da pasta analisada e registre também o hash do próprio manifesto: um único valor passa a proteger a lista inteira.

> **BOAS PRÁTICAS AO CALCULAR**
>
> Registre algoritmo, valor completo, nome e tamanho do arquivo, ferramenta e versão, data, hora, fuso e quem calculou. Compare o valor **inteiro** por comando (`-c` , `-eq`), não “de olho”. Quando possível, confira com uma segunda ferramenta: pelo determinismo, o resultado tem de ser igual. Calcule sobre o arquivo como foi recebido, antes de abrir, descompactar ou converter.

CAPÍTULO 07

Erros comuns

A matemática do SHA-256 raramente é o elo fraco. Os problemas costumam estar no que foi medido, quando foi medido e como o valor foi registrado.

Erro	Por que é um problema / o que fazer
Calcular o hash tarde demais	O hash só protege a partir do momento em que é calculado. Calcular depois de abrir, copiar várias vezes ou analisar deixa uma janela sem verificação. Calcule na coleta ou aquisição.
Usar só MD5 ou SHA-1	Ambos têm colisões práticas públicas (capítulo 04). Use SHA-256; se precisar de MD5/SHA-1 por compatibilidade, registre-os *junto* com o SHA-256.
Esquecer o `-a 256` no macOS	O `shasum` sem parâmetro calcula SHA-1. O valor terá 40 caracteres, não 64. Confira o tamanho.
Hash de texto com `echo`	`echo "abc" | sha256sum` inclui a quebra de linha e resulta em `edeaaff3…0efd18cb`, e não no vetor de `abc` (`ba7816bf…f20015ad`). Use `printf` ou calcule sobre o arquivo.
Achar que o nome faz parte do hash	O hash de arquivo cobre o *conteúdo*. Renomear ou mover não muda o valor; datas do sistema de arquivos e permissões também não entram. Esses dados precisam de registro próprio.
Confundir contêiner e conteúdo	O hash de um `.zip` é diferente do hash dos arquivos dentro dele. Da mesma forma, o hash do arquivo de uma imagem forense em formato com metadados e compressão (como E01) não é igual ao hash da mídia adquirida, que costuma ficar registrado dentro do próprio formato. Diga sempre *de que* é o hash.
Comparar só o começo do valor	Conferir os primeiros e últimos caracteres “de olho” é frágil e não é verificação. Compare o valor inteiro por comando.
Digitar o hash à mão	Erros de transcrição geram falsas divergências. Copie e cole a partir da saída da ferramenta e confira por comando.
Guardar o hash junto com o arquivo	Quem altera um pode alterar o outro. Mantenha o valor de referência em registro independente (capítulo 05).
Não registrar o contexto	Um valor solto, sem algoritmo, data, ferramenta e responsável, tem pouco valor demonstrativo.
Trabalhar sobre o original	Abrir um arquivo em certos programas pode alterá-lo ao salvar; montar uma mídia sem proteção contra escrita pode modificar dados do sistema de arquivos. Trabalhe sobre cópias verificadas.
Receber por aplicativo que recomprime	Aplicativos de mensagem e redes sociais podem recomprimir imagens, vídeos e áudios. O arquivo recebido pode ser *outro* arquivo, com outro hash e sem os metadados originais.
“Corrigir” uma divergência	Hash diferente é um fato a ser registrado e explicado, não um erro a ser apagado. Documente quando e como a divergência foi percebida.
Achar que hash prova autenticidade	Hash demonstra integridade a partir do cálculo, não veracidade, autoria ou data (capítulo 05).

CAPÍTULO 08

Cadeia de custódia no CPP (arts. 158-A a 158-F)

A Lei nº 13.964, de 24 de dezembro de 2019, incluiu no Código de Processo Penal (Decreto-Lei nº 3.689/1941) os arts. 158-A a 158-F, que disciplinam a cadeia de custódia dos vestígios.

SOBRE A FONTE E A VIGÊNCIA

Texto transcrito do CPP compilado no portal oficial da Presidência da República (planalto.gov.br/ccivil_03/decreto-lei/del3689.htm), consultado em 15/10/2026, e conferido com o texto da Lei nº 13.964/2019 no mesmo portal. No Planalto, cada dispositivo traz a anotação "(Incluído pela Lei nº 13.964, de 2019)". O art. 20 da Lei nº 13.964/2019 dispõe: "Esta Lei entra em vigor após decorridos 30 (trinta) dias de sua publicação oficial." A data de 23/01/2020 é a usualmente indicada como início da vigência **PONTO INCERTO** (não conferida pelo autor no Diário Oficial).

A transcrição segue a grafia do portal, inclusive em "ficando órgão central" (art. 158-C, § 1º), que aparece assim, sem artigo. O próprio portal adverte que seu texto não substitui o publicado no Diário Oficial da União.

Art. 158-A. Considera-se cadeia de custódia o conjunto de todos os procedimentos utilizados para manter e documentar a história cronológica do vestígio coletado em locais ou em vítimas de crimes, para rastrear sua posse e manuseio a partir de seu reconhecimento até o descarte.

§ 1º O início da cadeia de custódia dá-se com a preservação do local de crime ou com procedimentos policiais ou periciais nos quais seja detectada a existência de vestígio.

§ 2º O agente público que reconhecer um elemento como de potencial interesse para a produção da prova pericial fica responsável por sua preservação.

§ 3º Vestígio é todo objeto ou material bruto, visível ou latente, constatado ou recolhido, que se relaciona à infração penal.

Art. 158-B. A cadeia de custódia compreende o rastreamento do vestígio nas seguintes etapas:

I - reconhecimento: ato de distinguir um elemento como de potencial interesse para a produção da prova pericial;

II - isolamento: ato de evitar que se altere o estado das coisas, devendo isolar e preservar o ambiente imediato, mediato e relacionado aos vestígios e local de crime;

III - fixação: descrição detalhada do vestígio conforme se encontra no local de crime ou no corpo de delito, e a sua posição na área de exames, podendo ser ilustrada por fotografias, filmagens ou croqui, sendo indispensável a sua descrição no laudo pericial produzido pelo perito responsável pelo atendimento;

IV - coleta: ato de recolher o vestígio que será submetido à análise pericial, respeitando suas características e natureza;

V - acondicionamento: procedimento por meio do qual cada vestígio coletado é embalado de forma individualizada, de acordo com suas características físicas, químicas e biológicas, para posterior análise, com anotação da data, hora e nome de quem realizou a coleta e o acondicionamento;

VI - transporte: ato de transferir o vestígio de um local para o outro, utilizando as condições adequadas (embalagens, veículos, temperatura, entre outras), de modo a garantir a manutenção de suas características originais, bem como o controle de sua posse;

VII - recebimento: ato formal de transferência da posse do vestígio, que deve ser documentado com, no mínimo, informações referentes ao número de procedimento e unidade de polícia judiciária relacionada, local de origem, nome de quem transportou o vestígio, código de rastreamento, natureza do exame, tipo do vestígio, protocolo, assinatura e identificação de quem o recebeu;

VIII - processamento: exame pericial em si, manipulação do vestígio de acordo com a metodologia adequada às suas características biológicas, físicas e químicas, a fim de se obter o resultado desejado, que deverá ser formalizado em laudo produzido por perito;

IX - armazenamento: procedimento referente à guarda, em condições adequadas, do material a ser processado, guardado para realização de contraperícia, descartado ou transportado, com vinculação ao número do laudo correspondente;

X - descarte: procedimento referente à liberação do vestígio, respeitando a legislação vigente e, quando pertinente, mediante autorização judicial.

Art. 158-C. A coleta dos vestígios deverá ser realizada preferencialmente por perito oficial, que dará o encaminhamento necessário para a central de custódia, mesmo quando for necessária a realização de exames complementares.

§ 1º Todos vestígios coletados no decurso do inquérito ou processo devem ser tratados como descrito nesta Lei, ficando órgão central de perícia oficial de natureza criminal responsável por detalhar a forma do seu cumprimento.

§ 2º É proibida a entrada em locais isolados bem como a remoção de quaisquer vestígios de locais de crime antes da liberação por parte do perito responsável, sendo tipificada como fraude processual a sua realização.

Art. 158-D. O recipiente para acondicionamento do vestígio será determinado pela natureza do material.

§ 1º Todos os recipientes deverão ser selados com lacres, com numeração individualizada, de forma a garantir a inviolabilidade e a idoneidade do vestígio durante o transporte.

§ 2º O recipiente deverá individualizar o vestígio, preservar suas características, impedir contaminação e vazamento, ter grau de resistência adequado e espaço para registro de informações sobre seu conteúdo.

§ 3º O recipiente só poderá ser aberto pelo perito que vai proceder à análise e, motivadamente, por pessoa autorizada.

§ 4º Após cada rompimento de lacre, deve se fazer constar na ficha de acompanhamento de vestígio o nome e a matrícula do responsável, a data, o local, a finalidade, bem como as informações referentes ao novo lacre utilizado.

§ 5º O lacre rompido deverá ser acondicionado no interior do novo recipiente.

Art. 158-E. Todos os Institutos de Criminalística deverão ter uma central de custódia destinada à guarda e controle dos vestígios, e sua gestão deve ser vinculada diretamente ao órgão central de perícia oficial de natureza criminal.

§ 1º Toda central de custódia deve possuir os serviços de protocolo, com local para conferência, recepção, devolução de materiais e documentos, possibilitando a seleção, a classificação e a distribuição de materiais, devendo ser um espaço seguro e apresentar condições ambientais que não interfiram nas características do vestígio.

§ 2º Na central de custódia, a entrada e a saída de vestígio deverão ser protocoladas, consignando-se informações sobre a ocorrência no inquérito que a eles se relacionam.

§ 3º Todas as pessoas que tiverem acesso ao vestígio armazenado deverão ser identificadas e deverão ser registradas a data e a hora do acesso.

§ 4º Por ocasião da tramitação do vestígio armazenado, todas as ações deverão ser registradas, consignando-se a identificação do responsável pela tramitação, a destinação, a data e horário da ação.

Art. 158-F. Após a realização da perícia, o material deverá ser devolvido à central de custódia, devendo nela permanecer.

Parágrafo único. Caso a central de custódia não possua espaço ou condições de armazenar determinado material, deverá a autoridade policial ou judiciária determinar as condições de depósito do referido material em local diverso, mediante requerimento do diretor do órgão central de perícia oficial de natureza criminal.

Fonte: Decreto-Lei nº 3.689/1941 (CPP), texto compilado, arts. 158-A a 158-F, incluídos pela Lei nº 13.964/2019. Portal da Legislação, Presidência da República (planalto.gov.br). Consulta em 15/10/2026.

Leitura técnica: onde o hash entra

> **ATENÇÃO: ISTO É INTERPRETAÇÃO, NÃO TEXTO LEGAL**
>
> Os arts. 158-A a 158-F **não mencionam** prova digital, arquivos, dados ou funções hash. O texto fala em vestígios, recipientes e lacres, com vocabulário claramente pensado para o material físico ("características físicas, químicas e biológicas"). Aplicar essas etapas a vestígios digitais e associar o hash a elas é uma **leitura técnica do autor**, e não uma exigência expressa da lei PONTO INCERTO.

Etapa (art. 158-B)	Paralelo genérico no vestígio digital
I - Reconhecimento	Identificar dispositivos, mídias ou arquivos de potencial interesse.
II - Isolamento	Evitar que o estado dos dados se altere (por exemplo, por acesso remoto, sincronização ou uso do equipamento).
III - Fixação	Descrever e fotografar o estado do equipamento e da tela; registrar identificadores (modelo, número de série).
IV - Coleta	Aquisição ou cópia com método que preserve a origem; **calcular o hash da origem e/ou da cópia neste momento**.
V - Acondicionamento	Embalar e lacrar a mídia física; registrar os hashes junto com data, hora e responsável.
VI - Transporte	Controle de posse da mídia; o hash permite verificar, na chegada, que o conteúdo não mudou.
VII - Recebimento	Conferir lacre e documentação; quando cabível, recalcular e comparar o hash.
VIII - Processamento	Analisar sobre cópia verificada; registrar no laudo os hashes do material examinado e dos arquivos relevantes.
IX - Armazenamento	Guardar original e cópias; o hash permite verificar a integridade em uma contraperícia futura.
X - Descarte	Liberação conforme a legislação e, quando pertinente, mediante autorização judicial.

O ponto em comum é o art. 158-A: a cadeia de custódia é a **documentação da história cronológica** do vestígio. Para dados digitais, o hash é uma das ferramentas mais objetivas para mostrar que essa história é coerente: o que foi coletado é o que foi examinado e é o que está armazenado.

CAPÍTULO 09

Pontos jurídicos em aberto

O autor não é jurista, e este guia não é orientação jurídica. Abaixo, o que **não** foi verificado ou depende de interpretação. Antes de usar em prova, estudo ou trabalho, confira em fontes jurídicas atualizadas.

Ponto	Situação
Data exata de início da vigência INCERTO	O art. 20 da Lei nº 13.964/2019 fixa a vigência em 30 dias após a publicação oficial; a lei é datada de 24/12/2019. A data de 23/01/2020, usualmente indicada, não foi conferida pelo autor no Diário Oficial da União.
Efeito das ADIs no STF INCERTO	No Planalto, o art. 3º da Lei nº 13.964/2019 (que altera o CPP) traz as anotações "Vide ADI 6.298", "Vide ADI 6.299", "Vide ADI 6.300" e "Vide ADI 6.305". Essas ações são associadas sobretudo ao "juiz das garantias". O autor **não verificou** se alguma decisão nelas alcança os arts. 158-A a 158-F. No CPP compilado, consultado em 15/10/2026, esses seis artigos não trazem anotação "Vide ADI" nem indicação de suspensão.
Aplicação a vestígios digitais INCERTO	A lei não menciona prova digital nem hash. A extensão das etapas do art. 158-B a dados digitais e o papel do hash nelas são leitura técnica e doutrinária, não texto legal.
Consequência da quebra da cadeia de custódia INCERTO	Os arts. 158-A a 158-F **não dizem** o que acontece com a prova quando a cadeia é rompida (nulidade, inadmissibilidade, redução do valor probatório, necessidade de demonstrar prejuízo etc.). O tema é tratado pela doutrina e pela jurisprudência, que este guia não analisa.
Regulamentações complementares	O art. 158-C, § 1º, atribui ao "órgão central de perícia oficial de natureza criminal" detalhar a forma de cumprimento. Normas e procedimentos de órgãos específicos não são tratados aqui, por regra deste guia.
Algoritmo "exigido"	Nos dispositivos analisados não há exigência de algoritmo específico. A recomendação de SHA-256 neste guia é **técnica**, baseada em NIST, IETF e na literatura criptográfica, não em obrigação legal.
Normas técnicas citadas INCERTO	A ISO/IEC 27037 é citada como referência técnica geral. Sua versão vigente e sua adoção como norma ABNT no Brasil não foram conferidas pelo autor.
ICP-Brasil	A MP nº 2.200-2/2001 é mencionada no capítulo 05 apenas como referência para assinatura digital; seu regime jurídico e o valor probatório de documentos assinados não são analisados aqui.

COMO ESTUDAR ESTES PONTOS

- Leia o CPP compilado no Planalto observando as anotações "Vide" e "Vigência" ao lado de cada dispositivo. O Capítulo II do Título VII passou a se chamar "Do exame de corpo de delito, da cadeia de custódia e das perícias em geral" (redação dada pela Lei nº 13.964/2019).
- Consulte o andamento das ADIs diretamente no portal do STF.
- Para a consequência da quebra da cadeia, procure jurisprudência atualizada dos tribunais superiores e doutrina de processo penal, sempre verificando a data das decisões.

CAPÍTULO 10

Ferramenta, referências e leituras

HASHTABELA

Ferramenta gratuita do autor que calcula e organiza hashes SHA-256 de arquivos em tabela, no próprio navegador e sem enviar nada para a internet. Link: **https://sabero.io/hash/**. Os comandos nativos do capítulo 06 continuam sendo suficientes para tudo o que este guia descreve.

Legislação (fonte oficial)

1. BRASIL. Decreto-Lei nº 3.689, de 3 de outubro de 1941. Código de Processo Penal. Texto compilado, arts. 158-A a 158-F. Disponível em: https://www.planalto.gov.br/ccivil_03/decreto-lei/del3689.htm. Acesso em: 15 out. 2026.
2. BRASIL. Lei nº 13.964, de 24 de dezembro de 2019. Aperfeiçoa a legislação penal e processual penal. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2019-2022/2019/lei/l13964.htm. Acesso em: 15 out. 2026.

Padrões e documentos técnicos

3. NIST. FIPS 180-4: *Secure Hash Standard (SHS)*. 2015.
4. NIST. FIPS 202: *SHA-3 Standard: Permutation-Based Hash and Extendable-Output Functions*. 2015.
5. NIST. *NIST Retires SHA-1 Cryptographic Algorithm*. 15 dez. 2022. https://www.nist.gov/news-events/news/2022/12/nist-retires-sha-1-cryptographic-algorithm
6. RIVEST, R. RFC 1321: *The MD5 Message-Digest Algorithm*. IETF, abr. 1992.
7. TURNER, S.; CHEN, L. RFC 6151: *Updated Security Considerations for the MD5 Message-Digest and the HMAC-MD5 Algorithms*. IETF, mar. 2011. https://www.rfc-editor.org/rfc/rfc6151
8. ISO/IEC 27037: *Guidelines for identification, collection, acquisition and preservation of digital evidence*.

Criptoanálise de MD5 e SHA-1

9. WANG, X.; FENG, D.; LAI, X.; YU, H. *Collisions for Hash Functions MD4, MD5, HAVAL-128 and RIPEMD*. IACR ePrint 2004/199. https://eprint.iacr.org/2004/199
10. WANG, X.; YU, H. *How to Break MD5 and Other Hash Functions*. EUROCRYPT 2005, LNCS 3494.
11. STEVENS, M.; LENSTRA, A.; DE WEGER, B. *Chosen-prefix Collisions for MD5 and Colliding X.509 Certificates for Different Identities*. EUROCRYPT 2007.
12. STEVENS, M.; SOTIROV, A.; APPELBAUM, J.; LENSTRA, A.; MOLNAR, D.; OSVIK, D.; DE WEGER, B. *Short chosen-prefix collisions for MD5 and the creation of a rogue CA certificate*. CRYPTO 2009.
13. STEVENS, M.; BURSZTEIN, E.; KARPMAN, P.; ALBERTINI, A.; MARKOV, Y. *The first collision for full SHA-1*. CRYPTO 2017. IACR ePrint 2017/190. https://eprint.iacr.org/2017/190
14. GOOGLE. *Announcing the first SHA1 collision*. Google Online Security Blog, 23 fev. 2017. https://security.googleblog.com/2017/02/announcing-first-sha1-collision.html
15. LEURENT, G.; PEYRIN, T. *SHA-1 is a Shambles: First Chosen-Prefix Collision on SHA-1 and Application to the PGP Web of Trust*. USENIX Security 2020. IACR ePrint 2020/014. https://eprint.iacr.org/2020/014

Links acessados em 15/10/2026. O domínio shattered.io, historicamente associado ao projeto SHAttered, hoje também publica outros conteúdos; por isso, as referências preferidas aqui são o artigo no IACR ePrint e o anúncio do Google.

PARA IMPRIMIR

Checklist: hash e integridade

Lista de verificação genérica e educativa. Não substitui normas, procedimentos oficiais nem orientação jurídica.

ANTES DE CALCULAR

- [ ] Sei exatamente **de que** vou calcular o hash (mídia, imagem, arquivo, contêiner)
- [ ] O original não será aberto, editado nem montado com escrita
- [ ] Vou usar **SHA-256** (ou SHA-512 / SHA3-256)
- [ ] Se usar MD5/SHA-1 por compatibilidade, também registro SHA-256
- [ ] Conferi a ferramenta com um vetor de teste (entrada vazia = e3b0c442…7852b855)

AO CALCULAR

- [ ] macOS: `shasum -a 256` (com o `-a 256`)
- [ ] Linux: `sha256sum`
- [ ] Windows: `Get-FileHash -Algorithm SHA256`
- [ ] O valor tem **64** caracteres hexadecimais
- [ ] Calculei o mais cedo possível, idealmente na coleta
- [ ] Para pastas: manifesto fora da pasta + hash do manifesto

AO REGISTRAR

- [ ] Algoritmo e valor **completo**, copiado da saída (não digitado)
- [ ] Nome, caminho e tamanho em bytes do item
- [ ] Ferramenta e versão utilizadas
- [ ] Data, hora e fuso; quem calculou
- [ ] Registro **separado** do arquivo, em meio confiável
- [ ] Metadados fora do conteúdo (nome, datas) registrados à parte

AO CONFERIR

- [ ] Comparei por comando (`-c`, `-eq`), não "de olho"
- [ ] Comparei o valor inteiro, sem abreviar
- [ ] Maiúsculas/minúsculas não importam no hexadecimal
- [ ] Conferi com uma segunda ferramenta, quando possível
- [ ] Divergência registrada e investigada, nunca "corrigida"

CADEIA DE CUSTÓDIA (CPP)

- [ ] Conheço as 10 etapas do art. 158-B (do reconhecimento ao descarte)
- [ ] Transferências de posse documentadas (art. 158-B, VII)
- [ ] Lacres e rompimentos registrados (art. 158-D, §§ 1º a 5º)
- [ ] Acessos ao material identificados com data e hora (art. 158-E, § 3º)
- [ ] Hashes vinculados aos registros de cada etapa (leitura técnica, não texto legal)

LIMITES QUE NÃO ESQUEÇO

- [ ] Hash prova **integridade** a partir do cálculo, não autenticidade
- [ ] Hash não é criptografia e não anonimiza dados
- [ ] Hash guardado ao lado do arquivo não protege nada
- [ ] Arquivo recomprimido por aplicativo é outro arquivo
- [ ] Dúvida jurídica: consultar profissional habilitado

REGISTRO MÍNIMO DE UM HASH (MODELO PARA PREENCHER)

Item (o que foi medido):	Tamanho (bytes):
Algoritmo e valor:	
Ferramenta e versão:	Data, hora e fuso:
Responsável:	Onde o registro fica guardado:

Hash e integridade de arquivos na prova digital · Fernando Menolli Neto · Material educativo; não constitui orientação jurídica. Texto legal: CPP, arts. 158-A a 158-F (incluídos pela Lei nº 13.964/2019), conforme planalto.gov.br, consulta em 15/10/2026.